

# **Cybersecurity Risk Disclosure by Publicly Listed Firms: State, Drivers, and Consequences**

*A Research Brief on the Post-Mandate Landscape (2023-2026)*

## **Abstract**

*This research brief examines the cybersecurity risk disclosure landscape following the US Securities and Exchange Commission (SEC) landmark adoption of mandatory cybersecurity disclosure rules in July 2023. Drawing on regulatory filings, enforcement actions, comparative regulatory analysis across the US and EU frameworks, and emerging scholarly evidence, the brief maps the new institutional architecture of cyber risk reporting, identifies key compliance and materiality challenges, and highlights research opportunities at the intersection of cybersecurity, financial reporting, and capital markets.*

# 1. Introduction

On 26 July 2023, the SEC adopted final rules requiring publicly listed companies to disclose material cybersecurity incidents within four business days and to describe their cyber risk management, strategy, and governance processes in annual reports. These rules, codified under Form 8-K Item 1.05 and Regulation S-K Item 106, represent the most significant expansion of mandatory non-financial risk disclosure requirements since the adoption of Sarbanes-Oxley in 2002. For the accounting and finance research community, the advent of mandatory cyber risk disclosure opens a rich domain of inquiry at the intersection of information economics, voluntary and mandatory disclosure theory, and the materiality judgment framework that has long been central to securities regulation (Healy and Palepu, 2001; Beyer et al., 2010).

Cybersecurity has evolved from a narrow technical concern into a material business risk with implications for firm valuation, cost of capital, audit risk, and corporate governance. Cyber incidents impose direct costs: the average data breach cost reached USD 4.88 million in 2024, the highest on record (IBM/Ponemon, 2024). They also impose indirect costs through reputational damage, customer churn, regulatory penalties, and shareholder litigation. Kamiya et al. (2021), writing in the *Journal of Financial Economics*, document that successful cyberattacks decrease shareholder wealth by approximately 1.09 percent over a three-day window (an average value loss of USD 495 million per attack), harm firm reputation, reduce sales growth, and generate intra-industry contagion effects on non-breached peer firms. Following an attack, firms increase their risk management and IT spending and reduce management risk-taking incentives. Florackis et al. (2023), in the *Review of Financial Studies*, construct a text-based measure of cybersecurity risk from 10-K filings and show that portfolios of high-cybersecurity-risk firms earn an annual risk premium of up to 8.3 percent, and that their measure predicts future cyberattacks, suggesting that narrative disclosures contain economically meaningful signals even in the pre-mandate era.

The SEC rulemaking did not emerge in isolation. Globally, several major jurisdictions have enacted or revised cyber incident reporting requirements in the 2023-2025 window. The European Union adopted NIS2 (effective October 2024), expanding the scope of its cybersecurity directive to 18 critical sectors and introducing management accountability provisions. DORA (the Digital Operational Resilience Act), effective January 2025, imposes the world's most demanding incident reporting timeline (4 hours) on 21 categories of financial entities. The Australian Securities and Investments Commission (ASIC) has signalled heightened expectations for cyber governance disclosure. This regulatory convergence, combined with meaningful variation in institutional design across jurisdictions, creates a natural laboratory for comparative disclosure research.

The academic motivation is twofold. First, mandatory disclosure regimes provide exogenous variation that allows researchers to move beyond the endogeneity concerns that have long constrained the voluntary disclosure literature. The SEC rules create a clear pre-post treatment

structure, and the staggered adoption of NIS2 across EU member states provides additional identification opportunities. Second, cybersecurity disclosures raise fundamental questions about materiality. Whether an incident is material, and therefore reportable, involves complex judgments about financial magnitude, operational disruption, and reputational harm that are inherently forward-looking and uncertain. These judgments offer a window into how firms and their managers interpret and apply the materiality standard in practice, with implications that extend well beyond cybersecurity to climate risk, AI governance, and other emerging disclosure domains.

This brief proceeds as follows. Section 2 details the regulatory landscape across four frameworks: SEC rules, NIS2, DORA, and GDPR, concluding with a cross-jurisdictional comparison. The sections that follow (to be issued separately) will review market consequences, drivers of disclosure quality, and research gaps. The scope is limited to publicly listed firms in advanced economies, with emphasis on frameworks where mandatory disclosure requirements have demonstrably changed firm behaviour since 2023. The methodology draws on regulatory analysis of primary legal instruments, a synthesis of enforcement actions and practitioner surveys (Wilson Sonsini, 2025), and a review of the peer-reviewed accounting and finance literature published in ABS 4/4\* and ABDC A\* journals.

## **2. Regulatory Landscape and Its Evolution**

The SEC's cybersecurity disclosure rules, adopted on 26 July 2023, introduced two principal obligations for publicly listed companies (SEC, 2023). First, under Form 8-K Item 1.05, registrants must disclose any cybersecurity incident they determine to be material within four business days of that determination. The disclosure must describe the material aspects of the incident's nature, scope, and timing, as well as the material impact or reasonably likely material impact on the registrant's financial condition and results of operations. Second, under Regulation S-K Item 106, registrants must disclose in their annual Form 10-K: their processes for assessing, identifying, and managing material risks from cybersecurity threats; the board's oversight of cybersecurity risks; and management's role and expertise in assessing and managing such risks. The Form 8-K requirements took effect on 18 December 2023 (for all registrants except smaller reporting companies, for which the effective date was 15 June 2024). The Regulation S-K Item 106 requirements apply to annual reports for fiscal years ending on or after 15 December 2023.

The SEC's materiality framework draws on the standard articulated by the US Supreme Court in *TSC Industries v. Northway* (1976): a fact is material if there is "a substantial likelihood that a reasonable shareholder would consider it important" in making an investment decision. The *Basic v. Levinson* (1988) decision further refined this standard by linking materiality to "a substantial likelihood that the disclosure of the omitted fact would have been viewed by the reasonable investor as having significantly altered the 'total mix' of information made available." The SEC's adopting release explicitly acknowledged that materiality determinations for cybersecurity incidents are inherently fact-specific and may involve uncertainty about the

ultimate financial and operational consequences of an incident. The Commission declined to provide bright-line quantitative thresholds, consistent with its long-standing position that materiality is a qualitative judgment.

The rules also provide a narrow law enforcement delay provision: disclosure may be delayed if the US Attorney General determines that immediate disclosure would pose a substantial risk to national security or public safety. The delay is initially granted for 30 days, renewable for additional 30-day periods up to a maximum of 120 days (or 180 days in extraordinary circumstances). In practice, only one company (AT&T) is known to have used this provision during the first year (Wilson Sonsini, 2025).

On 21 May 2024, Erik Gerding, Director of the SEC's Division of Corporation Finance, issued a statement clarifying the Commission's interpretive position on several key issues (Gerding, 2024). The statement emphasised that the four-business-day clock begins only once the registrant has made a materiality determination, not upon discovery of the incident. It confirmed that Item 1.05 does not require disclosure of specific technical details about the registrant's incident response plans, cybersecurity systems, or potential vulnerabilities. It stated that the SEC does not view a ransomware payment alone as determinative of materiality, and it clarified that the SEC did not intend Item 1.05 filings to imply that the registrant's controls were ineffective solely because a breach occurred. This interpretive guidance arrived after significant practitioner concern that the rules would compel premature, technically incomplete, and potentially misleading disclosures.

The first year of implementation saw enforcement activity that clarified the SEC's posture. In October 2024, the SEC filed its first enforcement actions under the new rules against four companies: Unisys Corp., Avaya Holdings Corp., Check Point Software Technologies Ltd., and Mimecast Limited. Each settled with the SEC, agreeing to civil penalties, on charges that their disclosures of the SolarWinds Orion software supply chain compromise in 2020 materially understated the extent of the breach. This enforcement followed the SEC's earlier, separate action against SolarWinds Corporation itself: on 30 October 2023, the SEC filed a civil enforcement action against SolarWinds Corporation and its Chief Information Security Officer, Timothy Brown, alleging that they defrauded investors by overstating the company's cybersecurity practices and understating known risks in the period leading up to and following the 2020 SUNBURST attack (SEC v. SolarWinds Corp. and Brown, No. 1:23-cv-09518-PAE, S.D.N.Y., filed 30 October 2023). This action, which targets the CISO personally, represents the first time the SEC has charged an individual corporate cybersecurity officer with fraud and signals a significant escalation in personal accountability for cyber risk governance.

Empirical data on first-year filings provides important context. Wilson Sonsini (2025), in a comprehensive review of Item 1.05 filings from 18 December 2023 through 19 January 2025, identified 55 distinct cybersecurity incidents reported by 54 companies that triggered 80 separate Form 8-K filings (including amendments and updates). The average detection-to-filing interval was approximately 12 days, and roughly half of companies made their first filing within four

business days of incident detection. Approximately one-third of companies filed more than one Form 8-K for the same incident. Trade and services, finance, and technology firms were the most frequent filers.

*Key development (October 2024): The SEC charged SolarWinds and its CISO with civil fraud for alleged misrepresentations about cybersecurity practices and risk management. This action signals that the SEC views cybersecurity governance representations as within its enforcement remit and will hold individuals personally accountable for material misstatements.*

The EU Directive on measures for a high common level of cybersecurity across the Union (NIS2), adopted on 14 December 2022 and required to be transposed into national law by 17 October 2024, significantly expands the scope, obligations, and enforcement mechanisms of its predecessor (NIS1, 2016). NIS2 covers entities in 18 sectors, grouped into "essential" sectors (energy, transport, banking, financial market infrastructure, health, drinking water, wastewater, digital infrastructure, ICT service management, public administration, and space) and "important" sectors (postal and courier services, waste management, chemicals, food, manufacturing of certain critical products, digital providers, and research). The scope threshold is generally 50 or more employees or EUR 10 million in annual turnover, substantially broader than NIS1.

The incident reporting framework under NIS2 is notably more prescriptive than the SEC's approach. Covered entities must submit: (i) an early warning within 24 hours of becoming aware of a significant incident, indicating whether the incident is suspected to be caused by unlawful or malicious acts and whether it may have cross-border impact; (ii) an incident notification within 72 hours, updating the early warning and providing an initial assessment of severity, impact, and indicators of compromise; and (iii) a final report within one month, providing a detailed description of the incident, its root causes, mitigation measures, and cross-border effects (NIS2, Art. 23). The Commission may, by implementing act, specify the format and procedures for these notifications, suggesting a trajectory toward standardised, machine-readable incident reporting.

A distinctive feature of NIS2 is its emphasis on management accountability. Article 20 requires member states to ensure that management bodies of essential and important entities approve the cybersecurity risk management measures taken by the entity, oversee their implementation, and can be held liable for infringements. Management body members may be temporarily prohibited from exercising managerial functions where they are found to have breached their duties. This provision broadly parallels the SEC's Item 106 requirement for board oversight of cyber risk, but NIS2 goes further in explicitly linking management liability to supervisory failures, a feature absent from the SEC framework.

NIS2 also mandates that member states establish Computer Security Incident Response Teams (CSIRTs) as central coordination bodies, create national cybersecurity crisis management

frameworks, and impose significant penalties: up to EUR 10 million or 2% of total worldwide annual turnover for essential entities and EUR 7 million or 1.4% for important entities, whichever is higher. These penalties are substantially larger than those available under NIS1 and align NIS2 enforcement with the GDPR penalty framework, creating a consistent EU administrative enforcement architecture for data and cyber governance.

Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA), which entered into force on 17 January 2025, establishes a comprehensive framework for ICT risk management, incident reporting, digital operational resilience testing, and third-party ICT risk oversight within the EU financial sector. Unlike NIS2, which is a directive requiring national transposition, DORA is a directly applicable regulation, creating a single rulebook for all financial entities operating within the EU.

DORA applies to 21 categories of financial entities, including credit institutions, payment institutions, investment firms, crypto-asset service providers, insurance and reinsurance undertakings, credit rating agencies, statutory auditors and audit firms, and ICT third-party service providers. The scope is intentionally broad to capture the full financial sector ecosystem, reflecting the recognition that operational resilience failures in any part of the financial infrastructure can propagate systemic risk (European Commission, 2020).

DORA's incident reporting requirements are the most demanding of any major jurisdiction. Financial entities must report major ICT-related incidents according to a three-stage timeline: (i) an initial notification within 4 hours of classification (earlier than the standard applied by any other major framework), (ii) an intermediate report within 72 hours, and (iii) a final report within one month. The classification of an incident as "major" is determined by criteria including the number of clients affected, the duration of the incident, the geographical spread, data losses, and the criticality of services affected (DORA, Art. 18-20). The European Supervisory Authorities (ESAs) are empowered to develop draft regulatory technical standards specifying the content of these reports, which are expected to include detailed technical taxonomies aligned with the European Cyber Crisis Liaison Organisation Network (EU-CyCLONe) framework.

Beyond incident reporting, DORA introduces two structural innovations of relevance to disclosure research. First, it requires financial entities to conduct threat-led penetration testing (TLPT) at least every three years, simulating realistic cyber attack scenarios against critical or important functions. The results of TLPT must be reported to the competent authority and may trigger internal governance and disclosure implications. Second, DORA establishes a Union-wide oversight framework for critical ICT third-party service providers, including cloud computing platforms, data analytics services, and software providers. The ESAs are empowered to designate certain ICT providers as "critical" based on systemic importance, and such designations may have reputational and contractual consequences that are themselves disclosure-relevant.

The interaction between DORA and NIS2 raises important cross-regulatory questions. DORA functions as a *lex specialis* to NIS2 for financial entities, meaning that where DORA imposes

requirements that are at least equivalent to NIS2, the DORA provisions prevail. However, financial entities that are "essential" under NIS2 but fall outside DORA's scope (such as certain non-financial critical infrastructure operators) remain subject to NIS2's incident reporting and risk management framework. This regulatory layering creates a complex compliance landscape that is particularly acute for large, diversified financial groups operating across multiple EU member states.

The table below summarises key dimensions of the four major cyber incident reporting frameworks applicable to publicly listed firms in advanced economies. Although these frameworks differ in scope, reporting timeline, enforcement, and materiality standard, they all share a common trajectory toward mandatory, structured, and rapid incident disclosure. For researchers, this variation creates opportunities to examine whether more demanding reporting requirements improve market information environments or, conversely, generate defensive and boilerplate reporting behaviour.

**Table 1: Cross-Jurisdictional Comparison of Cybersecurity Incident Reporting Frameworks**

| Dimension                 | SEC (US)                                                | NIS2 (EU)                                     | DORA (EU)                                            | GDPR (EU)                                               |
|---------------------------|---------------------------------------------------------|-----------------------------------------------|------------------------------------------------------|---------------------------------------------------------|
| Effective date            | December 2023                                           | October 2024                                  | January 2025                                         | May 2018                                                |
| Scope                     | All SEC registrants                                     | 18 sectors; 50+ employees or EUR 10M turnover | 21 categories of financial entities                  | All entities processing personal data                   |
| Reporting trigger         | Materiality determination                               | Awareness of significant incident             | Classification as major ICT incident                 | Awareness of personal data breach                       |
| Initial timeline          | 4 business days                                         | 24 hours (early warning)                      | 4 hours (initial)                                    | 72 hours                                                |
| Follow-up                 | Amendments as needed                                    | 72h notification; 1 month final               | 72h intermediate; 1 month final                      | Follow-up without undue delay                           |
| Materiality standard      | Reasonable investor (TSC v. Northway)                   | Significant impact on service provision       | Criteria-based (clients, duration, criticality)      | Risk to rights and freedoms of natural persons          |
| Penalties                 | Civil penalties; individual liability; cease-and-desist | Up to EUR 10M or 2% of global turnover        | Determined by member states (GDPR-aligned)           | Up to EUR 20M or 4% of global turnover                  |
| Management accountability | Board oversight disclosure (S-K Item 106)               | Art. 20: direct management liability          | Management body responsibility for ICT risk          | Data Protection Officer obligations                     |
| Public disclosure         | Yes (Form 8-K)                                          | To competent authority; may inform public     | To competent authority; public if in public interest | To supervisory authority; to data subjects if high risk |

Note: Timelines reflect the initial reporting obligation after the relevant trigger event. SEC: materiality determination. NIS2: awareness of significant incident. DORA: classification as major. GDPR: awareness of personal data breach.

The variation across these frameworks is not merely procedural: it reflects fundamentally different regulatory philosophies. The SEC framework relies on a principles-based materiality standard, enforced through periodic filing obligations and ex post enforcement actions, with the

reasonable investor at its conceptual centre. NIS2 adopts a more prescriptive approach, with fixed timelines, standardised notification content, and explicit management accountability provisions. DORA extends this logic to its furthest point, imposing the shortest reporting interval globally (4 hours) and requiring proactive resilience testing. GDPR, while focused on personal data rather than systemic cyber risk, provides the most severe penalty framework and has served as a template for administrative enforcement design across EU digital regulation.

For multinational firms, the interaction of these frameworks creates practical compliance challenges. An incident involving personal data exfiltration from a financial entity's EU subsidiary could simultaneously trigger DORA (4-hour initial), NIS2 (24-hour early warning), GDPR (72-hour notification to supervisory authority and data subjects), and SEC Item 1.05 (4 business days from materiality determination). The practical burden of managing multiple reporting timelines with different materiality standards, notification recipients, and content requirements is substantial. Early practitioner commentary suggests that many multinational firms are defaulting to the fastest timeline (DORA's 4-hour window) for internal escalation, a form of regulatory ratcheting that may produce spillover effects on disclosure behaviour in jurisdictions with more lenient requirements.

## **2.1 SEC Cybersecurity Disclosure Rules**

The SEC's cybersecurity disclosure rules, adopted on 26 July 2023, introduced two principal obligations for publicly listed companies (SEC, 2023). First, under Form 8-K Item 1.05, registrants must disclose any cybersecurity incident they determine to be material within four business days of that determination. The disclosure must describe the material aspects of the incident's nature, scope, and timing, as well as the material impact or reasonably likely material impact on the registrant's financial condition and results of operations. Second, under Regulation S-K Item 106, registrants must disclose in their annual Form 10-K: their processes for assessing, identifying, and managing material risks from cybersecurity threats; the board's oversight of cybersecurity risks; and management's role and expertise in assessing and managing such risks. The Form 8-K requirements took effect on 18 December 2023 (for all registrants except smaller reporting companies, for which the effective date was 15 June 2024). The Regulation S-K Item 106 requirements apply to annual reports for fiscal years ending on or after 15 December 2023.

The SEC's materiality framework draws on the standard articulated by the US Supreme Court in *TSC Industries v. Northway* (1976): a fact is material if there is "a substantial likelihood that a reasonable shareholder would consider it important" in making an investment decision. The *Basic v. Levinson* (1988) decision further refined this standard by linking materiality to "a substantial likelihood that the disclosure of the omitted fact would have been viewed by the reasonable investor as having significantly altered the 'total mix' of information made available." The SEC's adopting release explicitly acknowledged that materiality determinations for cybersecurity incidents are inherently fact-specific and may involve uncertainty about the ultimate financial and operational consequences of an incident. The Commission declined to



provide bright-line quantitative thresholds, consistent with its long-standing position that materiality is a qualitative judgment.

The rules also provide a narrow law enforcement delay provision: disclosure may be delayed if the US Attorney General determines that immediate disclosure would pose a substantial risk to national security or public safety. The delay is initially granted for 30 days, renewable for additional 30-day periods up to a maximum of 120 days (or 180 days in extraordinary circumstances). In practice, only one company (AT&T) is known to have used this provision during the first year (Wilson Sonsini, 2025).

On 21 May 2024, Erik Gerding, Director of the SEC's Division of Corporation Finance, issued a statement clarifying the Commission's interpretive position on several key issues (Gerding, 2024). The statement emphasised that the four-business-day clock begins only once the registrant has made a materiality determination, not upon discovery of the incident. It confirmed that Item 1.05 does not require disclosure of specific technical details about the registrant's incident response plans, cybersecurity systems, or potential vulnerabilities. It stated that the SEC does not view a ransomware payment alone as determinative of materiality, and it clarified that the SEC did not intend Item 1.05 filings to imply that the registrant's controls were ineffective solely because a breach occurred. This interpretive guidance arrived after significant practitioner concern that the rules would compel premature, technically incomplete, and potentially misleading disclosures.

The first year of implementation saw enforcement activity that clarified the SEC's posture. In October 2024, the SEC filed its first enforcement actions under the new rules against four companies: Unisys Corp., Avaya Holdings Corp., Check Point Software Technologies Ltd., and Mimecast Limited. Each settled with the SEC, agreeing to civil penalties, on charges that their disclosures of the SolarWinds Orion software supply chain compromise in 2020 materially understated the extent of the breach. This enforcement followed the SEC's earlier, separate action against SolarWinds Corporation itself: on 30 October 2023, the SEC filed a civil enforcement action against SolarWinds Corporation and its Chief Information Security Officer, Timothy Brown, alleging that they defrauded investors by overstating the company's cybersecurity practices and understating known risks in the period leading up to and following the 2020 SUNBURST attack (SEC v. SolarWinds Corp. and Brown, No. 1:23-cv-09518-PAE, S.D.N.Y., filed 30 October 2023). This action, which targets the CISO personally, represents the first time the SEC has charged an individual corporate cybersecurity officer with fraud and signals a significant escalation in personal accountability for cyber risk governance.

Empirical data on first-year filings provides important context. Wilson Sonsini (2025), in a comprehensive review of Item 1.05 filings from 18 December 2023 through 19 January 2025, identified 55 distinct cybersecurity incidents reported by 54 companies that triggered 80 separate Form 8-K filings (including amendments and updates). The average detection-to-filing interval was approximately 12 days, and roughly half of companies made their first filing within four business days of incident detection. Approximately one-third of companies filed more than one

Form 8-K for the same incident. Trade and services, finance, and technology firms were the most frequent filers.

*Key development (October 2024): The SEC charged SolarWinds and its CISO with civil fraud for alleged misrepresentations about cybersecurity practices and risk management. This action signals that the SEC views cybersecurity governance representations as within its enforcement remit and will hold individuals personally accountable for material misstatements.*

## **2.2 EU NIS2 Directive**

The EU Directive on measures for a high common level of cybersecurity across the Union (NIS2), adopted on 14 December 2022 and required to be transposed into national law by 17 October 2024, significantly expands the scope, obligations, and enforcement mechanisms of its predecessor (NIS1, 2016). NIS2 covers entities in 18 sectors, grouped into "essential" sectors (energy, transport, banking, financial market infrastructure, health, drinking water, wastewater, digital infrastructure, ICT service management, public administration, and space) and "important" sectors (postal and courier services, waste management, chemicals, food, manufacturing of certain critical products, digital providers, and research). The scope threshold is generally 50 or more employees or EUR 10 million in annual turnover, substantially broader than NIS1.

The incident reporting framework under NIS2 is notably more prescriptive than the SEC's approach. Covered entities must submit: (i) an early warning within 24 hours of becoming aware of a significant incident, indicating whether the incident is suspected to be caused by unlawful or malicious acts and whether it may have cross-border impact; (ii) an incident notification within 72 hours, updating the early warning and providing an initial assessment of severity, impact, and indicators of compromise; and (iii) a final report within one month, providing a detailed description of the incident, its root causes, mitigation measures, and cross-border effects (NIS2, Art. 23). The Commission may, by implementing act, specify the format and procedures for these notifications, suggesting a trajectory toward standardised, machine-readable incident reporting.

A distinctive feature of NIS2 is its emphasis on management accountability. Article 20 requires member states to ensure that management bodies of essential and important entities approve the cybersecurity risk management measures taken by the entity, oversee their implementation, and can be held liable for infringements. Management body members may be temporarily prohibited from exercising managerial functions where they are found to have breached their duties. This provision broadly parallels the SEC's Item 106 requirement for board oversight of cyber risk, but NIS2 goes further in explicitly linking management liability to supervisory failures, a feature absent from the SEC framework.

NIS2 also mandates that member states establish Computer Security Incident Response Teams (CSIRTs) as central coordination bodies, create national cybersecurity crisis management frameworks, and impose significant penalties: up to EUR 10 million or 2% of total worldwide annual turnover for essential entities and EUR 7 million or 1.4% for important entities, whichever is higher. These penalties are substantially larger than those available under NIS1 and align NIS2 enforcement with the GDPR penalty framework, creating a consistent EU administrative enforcement architecture for data and cyber governance.

## **2.3 DORA (Digital Operational Resilience Act)**

Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA), which entered into force on 17 January 2025, establishes a comprehensive framework for ICT risk management, incident reporting, digital operational resilience testing, and third-party ICT risk oversight within the EU financial sector. Unlike NIS2, which is a directive requiring national transposition, DORA is a directly applicable regulation, creating a single rulebook for all financial entities operating within the EU.

DORA applies to 21 categories of financial entities, including credit institutions, payment institutions, investment firms, crypto-asset service providers, insurance and reinsurance undertakings, credit rating agencies, statutory auditors and audit firms, and ICT third-party service providers. The scope is intentionally broad to capture the full financial sector ecosystem, reflecting the recognition that operational resilience failures in any part of the financial infrastructure can propagate systemic risk (European Commission, 2020).

DORA's incident reporting requirements are the most demanding of any major jurisdiction. Financial entities must report major ICT-related incidents according to a three-stage timeline: (i) an initial notification within 4 hours of classification (earlier than the standard applied by any other major framework), (ii) an intermediate report within 72 hours, and (iii) a final report within one month. The classification of an incident as "major" is determined by criteria including the number of clients affected, the duration of the incident, the geographical spread, data losses, and the criticality of services affected (DORA, Art. 18-20). The European Supervisory Authorities (ESAs) are empowered to develop draft regulatory technical standards specifying the content of these reports, which are expected to include detailed technical taxonomies aligned with the European Cyber Crisis Liaison Organisation Network (EU-CyCLONe) framework.

Beyond incident reporting, DORA introduces two structural innovations of relevance to disclosure research. First, it requires financial entities to conduct threat-led penetration testing (TLPT) at least every three years, simulating realistic cyber attack scenarios against critical or important functions. The results of TLPT must be reported to the competent authority and may trigger internal governance and disclosure implications. Second, DORA establishes a Union-wide oversight framework for critical ICT third-party service providers, including cloud computing platforms, data analytics services, and software providers. The ESAs are empowered to designate certain ICT providers as "critical" based on systemic importance, and such

designations may have reputational and contractual consequences that are themselves disclosure-relevant.

The interaction between DORA and NIS2 raises important cross-regulatory questions. DORA functions as a *lex specialis* to NIS2 for financial entities, meaning that where DORA imposes requirements that are at least equivalent to NIS2, the DORA provisions prevail. However, financial entities that are "essential" under NIS2 but fall outside DORA's scope (such as certain non-financial critical infrastructure operators) remain subject to NIS2's incident reporting and risk management framework. This regulatory layering creates a complex compliance landscape that is particularly acute for large, diversified financial groups operating across multiple EU member states.

## 2.4 Cross-Jurisdictional Comparison

The table below summarises key dimensions of the four major cyber incident reporting frameworks applicable to publicly listed firms in advanced economies. Although these frameworks differ in scope, reporting timeline, enforcement, and materiality standard, they all share a common trajectory toward mandatory, structured, and rapid incident disclosure. For researchers, this variation creates opportunities to examine whether more demanding reporting requirements improve market information environments or, conversely, generate defensive and boilerplate reporting behaviour.

**Table 1: Cross-Jurisdictional Comparison of Cybersecurity Incident Reporting Frameworks**

| Dimension                 | SEC (US)                                                | NIS2 (EU)                                     | DORA (EU)                                       | GDPR (EU)                                      |
|---------------------------|---------------------------------------------------------|-----------------------------------------------|-------------------------------------------------|------------------------------------------------|
| Effective date            | December 2023                                           | October 2024                                  | January 2025                                    | May 2018                                       |
| Scope                     | All SEC registrants                                     | 18 sectors; 50+ employees or EUR 10M turnover | 21 categories of financial entities             | All entities processing personal data          |
| Reporting trigger         | Materiality determination                               | Awareness of significant incident             | Classification as major ICT incident            | Awareness of personal data breach              |
| Initial timeline          | 4 business days                                         | 24 hours (early warning)                      | 4 hours (initial)                               | 72 hours                                       |
| Follow-up                 | Amendments as needed                                    | 72h notification; 1 month final               | 72h intermediate; 1 month final                 | Follow-up without undue delay                  |
| Materiality standard      | Reasonable investor (TSC v. Northway)                   | Significant impact on service provision       | Criteria-based (clients, duration, criticality) | Risk to rights and freedoms of natural persons |
| Penalties                 | Civil penalties; individual liability; cease-and-desist | Up to EUR 10M or 2% of global turnover        | Determined by member states (GDPR-aligned)      | Up to EUR 20M or 4% of global turnover         |
| Management accountability | Board oversight disclosure (S-K Item 106)               | Art. 20: direct management liability          | Management body responsibility for ICT risk     | Data Protection Officer obligations            |

| Dimension         | SEC (US)       | NIS2 (EU)                                 | DORA (EU)                                            | GDPR (EU)                                               |
|-------------------|----------------|-------------------------------------------|------------------------------------------------------|---------------------------------------------------------|
| Public disclosure | Yes (Form 8-K) | To competent authority; may inform public | To competent authority; public if in public interest | To supervisory authority; to data subjects if high risk |

Note: Timelines reflect the initial reporting obligation after the relevant trigger event. SEC: materiality determination. NIS2: awareness of significant incident. DORA: classification as major. GDPR: awareness of personal data breach.

The variation across these frameworks is not merely procedural: it reflects fundamentally different regulatory philosophies. The SEC framework relies on a principles-based materiality standard, enforced through periodic filing obligations and ex post enforcement actions, with the reasonable investor at its conceptual centre. NIS2 adopts a more prescriptive approach, with fixed timelines, standardised notification content, and explicit management accountability provisions. DORA extends this logic to its furthest point, imposing the shortest reporting interval globally (4 hours) and requiring proactive resilience testing. GDPR, while focused on personal data rather than systemic cyber risk, provides the most severe penalty framework and has served as a template for administrative enforcement design across EU digital regulation.

For multinational firms, the interaction of these frameworks creates practical compliance challenges. An incident involving personal data exfiltration from a financial entity's EU subsidiary could simultaneously trigger DORA (4-hour initial), NIS2 (24-hour early warning), GDPR (72-hour notification to supervisory authority and data subjects), and SEC Item 1.05 (4 business days from materiality determination). The practical burden of managing multiple reporting timelines with different materiality standards, notification recipients, and content requirements is substantial. Early practitioner commentary suggests that many multinational firms are defaulting to the fastest timeline (DORA's 4-hour window) for internal escalation, a form of regulatory ratcheting that may produce spillover effects on disclosure behaviour in jurisdictions with more lenient requirements.

### 3. What Firms Actually Disclose

The first year of mandatory incident disclosure (18 December 2023 to approximately 19 January 2025) provides a rich window into how firms interpret and operationalise the SEC's materiality standard in practice. Wilson Sonsini (2025) tracked all cybersecurity incident filings on Form 8-K during this period and identified 55 distinct cybersecurity incidents reported by 54 companies, generating 80 total filings across Items 1.05, 8.01, and 7.01.

Several patterns are immediately apparent. First, approximately one-third of companies filed more than one Form 8-K for the same incident (19 of 55 incidents involved amendments), with the average interval between amendments of approximately 32 days. This pattern of iterative disclosure reflects the practical difficulty of assessing materiality and quantifying impact during an ongoing incident response. Second, only approximately 15 percent of companies (8 of 54) provided dollar-amount or person-count quantification of the incident's impact in their filings. The remaining companies relied on qualitative descriptions, often using language drawn from the

SEC's safe-harbour provisions. Third, the average time from detection to the first 8-K filing was approximately 12 days, with roughly half of companies filing within four business days of detection. This is notable given that the four-business-day clock runs from materiality determination, not discovery: the observed filing pattern suggests that materiality determinations are often made very close to the date of incident discovery.

The SEC's May 2024 guidance from Director Erik Gerding of the Division of Corporation Finance had a pronounced effect on filing behaviour. Before the guidance, 72 percent of filings were submitted under Item 1.05 (the mandatory material incident item). After the guidance, which explicitly stated that Item 1.05 is reserved for material incidents only, this proportion dropped to 34 percent, with companies shifting to Item 8.01 (other events) or Item 7.01 (Regulation FD disclosure) for incidents whose materiality remained undetermined or appeared immaterial. This behavioural shift demonstrates both the responsiveness of filers to regulatory signalling and the genuine ambiguity inherent in real-time materiality assessments during cybersecurity incidents.

Across the 80 filings in the first year, companies characterised the materiality of the reported incident as follows: approximately 14 percent described the incident as material (11 filings covering 9 distinct incidents), 33 percent described the incident as immaterial (26 filings), 28 percent stated that materiality had not yet been determined (22 filings), and the remaining 25 percent presented a mixed characterisation across multiple filings for the same incident. The prevalence of "undetermined" and mixed characterisations, comprising over half of all filings, underscores the practical difficulty of applying a forward-looking materiality standard to events whose consequences unfold over weeks and months.

The SEC's materiality framework, grounded in *TSC Industries v. Northway* (1976) and *Basic v. Levinson* (1988), requires firms to assess whether there is a substantial likelihood that a reasonable investor would consider the incident important in making an investment decision. For cybersecurity incidents, this requires consideration of both quantitative factors (financial costs, remediation expenses, lost revenue) and qualitative factors (harm to reputation, customer or vendor relationships, competitiveness, likelihood of litigation or regulatory investigation). The first-year data suggest that firms lean heavily on qualitative considerations in their materiality assessments, and that the absence of bright-line quantitative thresholds (in contrast to, for example, the quantitative significance tests in financial statement materiality) contributes to variability in disclosure practice.

A survey of 97 S&P 100 companies' Form 10-K Item 106 disclosures, conducted by Gibson Dunn and published via the Harvard Law School Forum on Corporate Governance (January 2025), provides the most comprehensive assessment of annual cybersecurity disclosure practices in the first year of implementation. The average disclosure length was approximately 980 words (range: 368 to 2,023 words), occupying roughly one and a half pages in the typical Form 10-K filing.

On risk management and strategy (Item 106(b)), disclosures were broad but varied in specificity. Nearly all companies discussed identity and access management, logging and monitoring, penetration testing, and risk assessment and threat intelligence. Approximately 84 percent discussed employee training programmes. About 87 percent noted the existence of an incident response plan, and 96 percent described the use of audits, drills, or tabletop exercises. Sixty percent of companies referenced external cybersecurity frameworks: the NIST Cybersecurity Framework was most common (cited by 51 of 97 companies), followed by ISO 27001/27002, SOC 1 and 2, and PCI DSS.

Third-party risk management was universally addressed, with 98 percent of companies disclosing engagement of external assessors, consultants, or auditors. All surveyed companies discussed third-party risk management processes; 90 percent described procedures for evaluating or monitoring vendor cybersecurity; and 42 percent required vendor adherence to specified cybersecurity management processes. The near-universal inclusion of third-party content reflects not only the regulatory requirement but also the growing prevalence of supply-chain attacks: the Verizon 2025 DBIR found that 30 percent of breaches involved third parties (up from 15 percent in 2024).

Item 106(c) requires firms to describe both the board's oversight of cybersecurity risk and management's role in assessing and managing material cybersecurity risks. The Gibson Dunn survey reveals several patterns in how the largest U.S. public companies have operationalised these requirements.

On board oversight, 68 percent of companies reported that the full board is responsible for enterprise-wide risk oversight including cybersecurity. However, 66 percent also delegated primary cybersecurity oversight responsibility to a committee or subcommittee. Among companies that delegated to a committee, the audit committee was the most common choice (78 percent), followed by a dedicated risk committee (19 percent). Only 6 percent of companies reported that the full board retained primary oversight without committee delegation. This pattern is consistent with pre-existing research showing that cybersecurity oversight typically follows the same governance channels as financial reporting and internal control oversight (Higgs et al., 2016; Hartmann and Carmenate, 2021).

On management's role, 99 percent of companies listed one or more management positions responsible for cybersecurity. The Chief Information Security Officer (CISO) was identified by name or title in 78 percent of disclosures. Approximately 88 percent described the experience or qualifications of the responsible individuals, typically noting 15 to 30 or more years of relevant experience. About 43 percent also reported the existence of a management-level cybersecurity committee. Communication cadence between management and the board was described with increasing specificity in the 2025 filings, with leading issuers describing reporting cycles aligned to the same cadence as financial reporting and internal control updates (Harvard Law School Forum, 2025).

### **3.1 Incident Reporting under Form 8-K Item 1.05**

The first year of mandatory incident disclosure (18 December 2023 to approximately 19 January 2025) provides a rich window into how firms interpret and operationalise the SEC's materiality standard in practice. Wilson Sonsini (2025) tracked all cybersecurity incident filings on Form 8-K during this period and identified 55 distinct cybersecurity incidents reported by 54 companies, generating 80 total filings across Items 1.05, 8.01, and 7.01.

Several patterns are immediately apparent. First, approximately one-third of companies filed more than one Form 8-K for the same incident (19 of 55 incidents involved amendments), with the average interval between amendments of approximately 32 days. This pattern of iterative disclosure reflects the practical difficulty of assessing materiality and quantifying impact during an ongoing incident response. Second, only approximately 15 percent of companies (8 of 54) provided dollar-amount or person-count quantification of the incident's impact in their filings. The remaining companies relied on qualitative descriptions, often using language drawn from the SEC's safe-harbour provisions. Third, the average time from detection to the first 8-K filing was approximately 12 days, with roughly half of companies filing within four business days of detection. This is notable given that the four-business-day clock runs from materiality determination, not discovery: the observed filing pattern suggests that materiality determinations are often made very close to the date of incident discovery.

The SEC's May 2024 guidance from Director Erik Gerding of the Division of Corporation Finance had a pronounced effect on filing behaviour. Before the guidance, 72 percent of filings were submitted under Item 1.05 (the mandatory material incident item). After the guidance, which explicitly stated that Item 1.05 is reserved for material incidents only, this proportion dropped to 34 percent, with companies shifting to Item 8.01 (other events) or Item 7.01 (Regulation FD disclosure) for incidents whose materiality remained undetermined or appeared immaterial. This behavioural shift demonstrates both the responsiveness of filers to regulatory signalling and the genuine ambiguity inherent in real-time materiality assessments during cybersecurity incidents.

### **3.2 Materiality Judgments in Practice**

Across the 80 filings in the first year, companies characterised the materiality of the reported incident as follows: approximately 14 percent described the incident as material (11 filings covering 9 distinct incidents), 33 percent described the incident as immaterial (26 filings), 28 percent stated that materiality had not yet been determined (22 filings), and the remaining 25 percent presented a mixed characterisation across multiple filings for the same incident. The prevalence of "undetermined" and mixed characterisations, comprising over half of all filings, underscores the practical difficulty of applying a forward-looking materiality standard to events whose consequences unfold over weeks and months.



The SEC's materiality framework, grounded in *TSC Industries v. Northway* (1976) and *Basic v. Levinson* (1988), requires firms to assess whether there is a substantial likelihood that a reasonable investor would consider the incident important in making an investment decision. For cybersecurity incidents, this requires consideration of both quantitative factors (financial costs, remediation expenses, lost revenue) and qualitative factors (harm to reputation, customer or vendor relationships, competitiveness, likelihood of litigation or regulatory investigation). The first-year data suggest that firms lean heavily on qualitative considerations in their materiality assessments, and that the absence of bright-line quantitative thresholds (in contrast to, for example, the quantitative significance tests in financial statement materiality) contributes to variability in disclosure practice.

### **3.3 Annual Disclosure under Regulation S-K Item 106**

A survey of 97 S&P 100 companies' Form 10-K Item 106 disclosures, conducted by Gibson Dunn and published via the Harvard Law School Forum on Corporate Governance (January 2025), provides the most comprehensive assessment of annual cybersecurity disclosure practices in the first year of implementation. The average disclosure length was approximately 980 words (range: 368 to 2,023 words), occupying roughly one and a half pages in the typical Form 10-K filing.

On risk management and strategy (Item 106(b)), disclosures were broad but varied in specificity. Nearly all companies discussed identity and access management, logging and monitoring, penetration testing, and risk assessment and threat intelligence. Approximately 84 percent discussed employee training programmes. About 87 percent noted the existence of an incident response plan, and 96 percent described the use of audits, drills, or tabletop exercises. Sixty percent of companies referenced external cybersecurity frameworks: the NIST Cybersecurity Framework was most common (cited by 51 of 97 companies), followed by ISO 27001/27002, SOC 1 and 2, and PCI DSS.

Third-party risk management was universally addressed, with 98 percent of companies disclosing engagement of external assessors, consultants, or auditors. All surveyed companies discussed third-party risk management processes; 90 percent described procedures for evaluating or monitoring vendor cybersecurity; and 42 percent required vendor adherence to specified cybersecurity management processes. The near-universal inclusion of third-party content reflects not only the regulatory requirement but also the growing prevalence of supply-chain attacks: the Verizon 2025 DBIR found that 30 percent of breaches involved third parties (up from 15 percent in 2024).

### **3.4 Board Oversight and Governance Disclosures**

Item 106(c) requires firms to describe both the board's oversight of cybersecurity risk and management's role in assessing and managing material cybersecurity risks. The Gibson Dunn

survey reveals several patterns in how the largest U.S. public companies have operationalised these requirements.

On board oversight, 68 percent of companies reported that the full board is responsible for enterprise-wide risk oversight including cybersecurity. However, 66 percent also delegated primary cybersecurity oversight responsibility to a committee or subcommittee. Among companies that delegated to a committee, the audit committee was the most common choice (78 percent), followed by a dedicated risk committee (19 percent). Only 6 percent of companies reported that the full board retained primary oversight without committee delegation. This pattern is consistent with pre-existing research showing that cybersecurity oversight typically follows the same governance channels as financial reporting and internal control oversight (Higgs et al., 2016; Hartmann and Carmenate, 2021).

On management's role, 99 percent of companies listed one or more management positions responsible for cybersecurity. The Chief Information Security Officer (CISO) was identified by name or title in 78 percent of disclosures. Approximately 88 percent described the experience or qualifications of the responsible individuals, typically noting 15 to 30 or more years of relevant experience. About 43 percent also reported the existence of a management-level cybersecurity committee. Communication cadence between management and the board was described with increasing specificity in the 2025 filings, with leading issuers describing reporting cycles aligned to the same cadence as financial reporting and internal control updates (Harvard Law School Forum, 2025).

## **4. Cross-Industry and Cross-Country Variation in Disclosure Practices**

The distribution of Form 8-K cybersecurity incident filings by industry during the first year reveals that cybersecurity incidents are not evenly distributed across economic sectors. Based on SEC Standard Industrial Classification (SIC) groupings, Trade and Services firms accounted for 31.5 percent of all filings, followed by Finance (18.5 percent), Technology (14.8 percent), Industrial (14.8 percent), Manufacturing (13.0 percent), Energy and Transportation (5.6 percent), and Real Estate and Construction (1.9 percent).

Several interpretations are possible. The high proportion in Trade and Services may reflect the sector's reliance on consumer-facing digital platforms and payment systems, which create large attack surfaces. The Finance sector's share is consistent with the Verizon DBIR's finding that financial services firms report the broadest exposure to cyber threats (78 percent reporting attacks). However, these filing counts should not be interpreted as incidence rates: without reliable denominators (total firms per SIC group among SEC registrants), the observed distribution conflates sector size, attack propensity, detection capability, and materiality assessment practices.

While the SEC rules apply only to U.S.-listed companies, the global landscape of cybersecurity disclosure is fragmenting along jurisdictional lines. The OECD (2026) has identified regulatory fragmentation as a growing concern for international business, noting that the proliferation of cybersecurity regulations across jurisdictions creates compliance complexity for multinational firms. Key differences include the trigger for mandatory reporting (materiality determination versus awareness versus incident classification), the timeline for reporting (from four hours to four business days), the recipient of the report (investors versus regulators versus data subjects), and the content of the required disclosure.

In the European Union, NIS2 creates a common cybersecurity baseline across 18 critical sectors, but member states retain some discretion in implementation. For example, some member states have chosen to include additional sectors beyond the directive's minimum scope. In the Asia-Pacific region, Australia's Security Legislation Amendment (Critical Infrastructure) Act 2022 imposes cybersecurity obligations on critical infrastructure entities; Japan's amendment to the Financial Instruments and Exchange Act in 2023 requires disclosure of cybersecurity governance in annual securities reports; and China's Cybersecurity Law, Data Security Law, and Personal Information Protection Law create a comprehensive but distinct regulatory architecture.

The resulting patchwork presents significant research opportunities. Few studies have examined whether regulatory stringency in one jurisdiction produces disclosure spillovers in others, whether firms in jurisdictions with stricter requirements experience different capital market outcomes, or whether multinational firms harmonise their cybersecurity practices across jurisdictions or maintain jurisdiction-specific approaches.

Research on pre-mandate voluntary cybersecurity disclosure consistently finds substantial variation in both the quantity and quality of disclosures across firms. Florackis et al. (2023) construct a text-based measure of cybersecurity risk from 10-K filings and document persistent cross-sectional variation even within industries. Sheneman (forthcoming, TAR) documents that cybersecurity risk disclosure varies systematically with firm characteristics including size, leverage, and analyst following.

Early evidence on mandated disclosure under Item 106 suggests that this variation has not been eliminated. The Gibson Dunn (2025) survey of S&P 100 companies found disclosure length ranging from 368 to 2,023 words, with corresponding variation in specificity and granularity. A small number of companies provided detailed quantitative metrics on cybersecurity programme elements (such as frequency of penetration testing, number of tabletop exercises, and third-party assessment cadence). Most companies provided qualitative descriptions without quantitative benchmarks.

Research by Haislip et al. (2026), published in the *International Journal of Accounting Information Systems*, uses textual analysis of 3,440 Item 1C disclosures from 2024 10-K filings. Their key finding is that the Kullback-Leibler divergence between Item 1A (risk factors) and Item 1C (cybersecurity) in 2024 is 5.92, indicating fundamentally distinct topic distributions. Item 1C shifts emphasis toward risk processes (43 percent of content), board oversight (20

percent), and management role (13 percent), whereas Item 1A cybersecurity risk factor disclosure is oriented toward enumerating threat types and potential adverse outcomes. This structural disconnect between prior voluntary disclosure practices and the governance focus of Item 106 suggests that mandated disclosure under Section 106 generates new information content beyond what was previously available to investors through voluntary channels.

#### **4.1 Industry-Level Distribution of Incident Filings**

The distribution of Form 8-K cybersecurity incident filings by industry during the first year reveals that cybersecurity incidents are not evenly distributed across economic sectors. Based on SEC Standard Industrial Classification (SIC) groupings, Trade and Services firms accounted for 31.5 percent of all filings, followed by Finance (18.5 percent), Technology (14.8 percent), Industrial (14.8 percent), Manufacturing (13.0 percent), Energy and Transportation (5.6 percent), and Real Estate and Construction (1.9 percent).

Several interpretations are possible. The high proportion in Trade and Services may reflect the sector's reliance on consumer-facing digital platforms and payment systems, which create large attack surfaces. The Finance sector's share is consistent with the Verizon DBIR's finding that financial services firms report the broadest exposure to cyber threats (78 percent reporting attacks). However, these filing counts should not be interpreted as incidence rates: without reliable denominators (total firms per SIC group among SEC registrants), the observed distribution conflates sector size, attack propensity, detection capability, and materiality assessment practices.

#### **4.2 Cross-Country Variation**

While the SEC rules apply only to U.S.-listed companies, the global landscape of cybersecurity disclosure is fragmenting along jurisdictional lines. The OECD (2026) has identified regulatory fragmentation as a growing concern for international business, noting that the proliferation of cybersecurity regulations across jurisdictions creates compliance complexity for multinational firms. Key differences include the trigger for mandatory reporting (materiality determination versus awareness versus incident classification), the timeline for reporting (from four hours to four business days), the recipient of the report (investors versus regulators versus data subjects), and the content of the required disclosure.

In the European Union, NIS2 creates a common cybersecurity baseline across 18 critical sectors, but member states retain some discretion in implementation. For example, some member states have chosen to include additional sectors beyond the directive's minimum scope. In the Asia-Pacific region, Australia's Security Legislation Amendment (Critical Infrastructure) Act 2022 imposes cybersecurity obligations on critical infrastructure entities; Japan's amendment to the Financial Instruments and Exchange Act in 2023 requires disclosure of cybersecurity governance in annual securities reports; and China's Cybersecurity Law, Data Security Law, and Personal Information Protection Law create a comprehensive but distinct regulatory architecture.

The resulting patchwork presents significant research opportunities. Few studies have examined whether regulatory stringency in one jurisdiction produces disclosure spillovers in others, whether firms in jurisdictions with stricter requirements experience different capital market outcomes, or whether multinational firms harmonise their cybersecurity practices across jurisdictions or maintain jurisdiction-specific approaches.

### **4.3 Disclosure Quantity and Quality Variation**

Research on pre-mandate voluntary cybersecurity disclosure consistently finds substantial variation in both the quantity and quality of disclosures across firms. Florackis et al. (2023) construct a text-based measure of cybersecurity risk from 10-K filings and document persistent cross-sectional variation even within industries. Sheneman (forthcoming, TAR) documents that cybersecurity risk disclosure varies systematically with firm characteristics including size, leverage, and analyst following.

Early evidence on mandated disclosure under Item 106 suggests that this variation has not been eliminated. The Gibson Dunn (2025) survey of S&P 100 companies found disclosure length ranging from 368 to 2,023 words, with corresponding variation in specificity and granularity. A small number of companies provided detailed quantitative metrics on cybersecurity programme elements (such as frequency of penetration testing, number of tabletop exercises, and third-party assessment cadence). Most companies provided qualitative descriptions without quantitative benchmarks.

Research by Haislip et al. (2026), published in the *International Journal of Accounting Information Systems*, uses textual analysis of 3,440 Item 1C disclosures from 2024 10-K filings. Their key finding is that the Kullback-Leibler divergence between Item 1A (risk factors) and Item 1C (cybersecurity) in 2024 is 5.92, indicating fundamentally distinct topic distributions. Item 1C shifts emphasis toward risk processes (43 percent of content), board oversight (20 percent), and management role (13 percent), whereas Item 1A cybersecurity risk factor disclosure is oriented toward enumerating threat types and potential adverse outcomes. This structural disconnect between prior voluntary disclosure practices and the governance focus of Item 106 suggests that mandated disclosure under Section 106 generates new information content beyond what was previously available to investors through voluntary channels.

## **5. Firm-Level Determinants of Cybersecurity Disclosure**

Firm size is consistently the most robust predictor of cybersecurity disclosure quantity and quality in the pre-mandate literature. Larger firms face greater public scrutiny, have more substantial resources to invest in cybersecurity programmes, and are more likely targets of attacks, all of which create incentives for more extensive disclosure. Gao et al. (2020) find that disclosure length increases linearly over time, and that larger firms, on average, provide more extensive cybersecurity risk disclosures, consistent with a political cost explanation.

Industry membership is also a significant determinant, but the direction of the effect varies by study. IT-intensive industries (technology, finance, telecommunications) naturally have more cybersecurity risk to disclose. However, prior to the mandate, some firms in these industries may have strategically limited disclosure to avoid revealing vulnerabilities. The literature on the relationship between industry competition and disclosure is mixed: some studies find that firms in more competitive industries disclose less to protect proprietary information, while others find that competitive pressure increases transparency as a differentiation mechanism.

A systematic review of 203 empirical studies (2024, *Australian Journal of Management*) identifies board governance as a key determinant of cybersecurity disclosure. Board independence is positively associated with more extensive cybersecurity disclosure (Alodat et al., 2024; Mazumder and Hossain, 2023; Smaili et al., 2023). Gender diversity on the board is also consistently associated with more extensive cybersecurity disclosure (Elnahass et al., 2024; Mazumder and Hossain, 2023; Radu and Smaili, 2022).

Board-level cybersecurity or technology expertise has emerged as a particularly important determinant. Hartmann and Carmenate (2021, *Current Issues in Auditing*) document that companies with technology experts on their boards are more likely to disclose cybersecurity risk management practices. However, a forthcoming study in the *Journal of Accounting and Economics* (2025) finds that while cybersecurity expertise at the board level has steadily increased, it remains at relatively low absolute levels. Moreover, the effect of board cybersecurity expertise on disclosure quality is diminished when board oversight is "symbolic" (entailing formal designation without dedicated committees or regular engagement with management).

CEO characteristics also matter. Trinh et al. (2025) find that CEOs with PhDs are associated with reduced cybersecurity disclosure likelihood and length, while CEOs with multiple directorships are associated with the opposite effect. Lin and She (2024) document a concerning pattern: insider net selling before cybersecurity incident discovery dates is associated with subsequent disclosure behaviour, raising questions about whether some managers exploit information asymmetries around cyber incidents.

Prior cybersecurity breaches are a strong predictor of subsequent disclosure behaviour. Kamiya et al. (2021, *JFE*) show that firms that have experienced a successful cyberattack subsequently increase their risk management and IT spending and modify their management risk-taking incentives. The Gibson Dunn (2025) survey notes that firms with a history of material cybersecurity incidents tend to provide more detailed Item 106 disclosures, consistent with a learning effect in which breach experience creates both enhanced internal awareness and external pressure for transparent communication.

Regulatory exposure, measured by indicators such as the number of SEC comment letters, industry regulatory intensity, or cross-listing status, is also associated with more extensive cybersecurity disclosure. Firms in regulated industries such as financial services and healthcare,

which face cybersecurity requirements from sector-specific regulators in addition to the SEC, tend to disclose more extensively than firms in less regulated industries.

## **5.1 Firm Size and Industry**

Firm size is consistently the most robust predictor of cybersecurity disclosure quantity and quality in the pre-mandate literature. Larger firms face greater public scrutiny, have more substantial resources to invest in cybersecurity programmes, and are more likely targets of attacks, all of which create incentives for more extensive disclosure. Gao et al. (2020) find that disclosure length increases linearly over time, and that larger firms, on average, provide more extensive cybersecurity risk disclosures, consistent with a political cost explanation.

Industry membership is also a significant determinant, but the direction of the effect varies by study. IT-intensive industries (technology, finance, telecommunications) naturally have more cybersecurity risk to disclose. However, prior to the mandate, some firms in these industries may have strategically limited disclosure to avoid revealing vulnerabilities. The literature on the relationship between industry competition and disclosure is mixed: some studies find that firms in more competitive industries disclose less to protect proprietary information, while others find that competitive pressure increases transparency as a differentiation mechanism.

## **5.2 Board Governance and Expertise**

A systematic review of 203 empirical studies (2024, Australian Journal of Management) identifies board governance as a key determinant of cybersecurity disclosure. Board independence is positively associated with more extensive cybersecurity disclosure (Alodat et al., 2024; Mazumder and Hossain, 2023; Smaili et al., 2023). Gender diversity on the board is also consistently associated with more extensive cybersecurity disclosure (Elnahass et al., 2024; Mazumder and Hossain, 2023; Radu and Smaili, 2022).

Board-level cybersecurity or technology expertise has emerged as a particularly important determinant. Hartmann and Carmenate (2021, Current Issues in Auditing) document that companies with technology experts on their boards are more likely to disclose cybersecurity risk management practices. However, a forthcoming study in the Journal of Accounting and Economics (2025) finds that while cybersecurity expertise at the board level has steadily increased, it remains at relatively low absolute levels. Moreover, the effect of board cybersecurity expertise on disclosure quality is diminished when board oversight is "symbolic" (entailing formal designation without dedicated committees or regular engagement with management).

CEO characteristics also matter. Trinh et al. (2025) find that CEOs with PhDs are associated with reduced cybersecurity disclosure likelihood and length, while CEOs with multiple directorships are associated with the opposite effect. Lin and She (2024) document a concerning pattern: insider net selling before cybersecurity incident discovery dates is associated with

subsequent disclosure behaviour, raising questions about whether some managers exploit information asymmetries around cyber incidents.

### **5.3 Prior Breaches and Regulatory Exposure**

Prior cybersecurity breaches are a strong predictor of subsequent disclosure behaviour. Kamiya et al. (2021, JFE) show that firms that have experienced a successful cyberattack subsequently increase their risk management and IT spending and modify their management risk-taking incentives. The Gibson Dunn (2025) survey notes that firms with a history of material cybersecurity incidents tend to provide more detailed Item 106 disclosures, consistent with a learning effect in which breach experience creates both enhanced internal awareness and external pressure for transparent communication.

Regulatory exposure, measured by indicators such as the number of SEC comment letters, industry regulatory intensity, or cross-listing status, is also associated with more extensive cybersecurity disclosure. Firms in regulated industries such as financial services and healthcare, which face cybersecurity requirements from sector-specific regulators in addition to the SEC, tend to disclose more extensively than firms in less regulated industries.

## **6. Capital Market and Firm Consequences**

Cybersecurity breaches produce negative and statistically significant stock price reactions. Kamiya et al. (2021, JFE) document that successful cyberattacks lead to negative stock price reactions and significant loss of sales growth for target firms, with average cumulative abnormal returns (CARs) in the range of negative 1 to 3 percent over short event windows. The effect extends beyond the target firm: there is evidence of intra-industry contagion, with non-breached firms in the same industry experiencing negative abnormal returns around major breach announcements.

A 2025 study in the *Journal of Banking Regulation* examining 53 global cyberattacks finds negative and statistically significant stock price reactions for breached firms around disclosure dates, with stronger reactions for small firms, high-leverage firms, high-growth-opportunity firms, and incidents involving financial information loss. This heterogeneity is important: it suggests that cybersecurity risk interacts with other firm-level risk factors to determine market impact, and that the nature of the compromised information matters alongside the fact of the breach itself.

On the disclosure side, the relationship between disclosure and stock price crash risk is nuanced. A 2024 study in the *International Review of Economics and Finance* finds that data breach disclosures (mandated by state-level Data Breach Notification laws) are associated with increased stock price crash risk, consistent with the argument that disclosure of bad news can itself trigger panic selling. However, research in the *Journal of Corporate Accounting and Finance* (Vol. 36, Issue 3) finds that higher frequency of cybersecurity disclosures (presumably



reflecting ongoing risk management communication rather than incident-driven disclosure) is associated with reduced stock price crash risk. The distinction between incident-triggered disclosure and routine risk management disclosure appears critical to understanding disclosure effects.

A growing body of evidence links cybersecurity risk to firms' cost of capital. Sheneman (forthcoming, TAR) provides the most direct evidence on the debt market channel: she documents a positive association between cybersecurity risk and the cost of bank debt, with loans initiated after a breach carrying spreads approximately 30 basis points higher than loans to non-breached firms. The effect is more pronounced for firms with lower pre-breach credit ratings, suggesting that cybersecurity risk compounds existing credit risk rather than operating as an independent factor.

Huang and Wang (2021) show that the passage of state-level Data Breach Notification laws increased breach disclosure rates, which in turn exposed lenders to greater cash flow risk from breach-related costs. On the equity side, Chen et al. (2023, *Journal of Business Ethics*) find that detailed cybersecurity risk factor disclosures reduce information asymmetry and are associated with a lower cost of equity. Wang et al. (2023, *Journal of Accounting and Public Policy*) document a positive association between cybersecurity risk and the cost of equity capital, but find that this association is moderated by the quality of board oversight: firms with strong board-level cybersecurity governance exhibit a weaker relationship between cyber risk and cost of equity.

Havakhor et al. (2020) examine the relationship between cybersecurity investment disclosure and firms' financing costs. They find that digital cybersecurity investments show a stronger negative association with cost of equity compared to cost of debt, consistent with the argument that equity holders, who hold residual claims on firm value, are more exposed to the downside risk of cybersecurity failures and therefore more sensitive to investments that mitigate that risk.

The SEC's October 2024 enforcement actions against four companies for materially misleading disclosures related to the SolarWinds Orion intrusion signal a new era of regulatory scrutiny over cybersecurity disclosure (SEC, 2024). Total civil penalties in these four actions amounted to approximately USD 7 million. Beyond SEC enforcement, shareholder derivative lawsuits and securities class actions following cybersecurity incidents are increasing. The combination of mandatory incident reporting (creating a publicly available record of incidents) and the SEC's demonstrated willingness to pursue disclosure violations creates a new litigation environment for public companies.

Kamiya et al. (2021) document that beyond direct financial costs, cybersecurity breaches damage firm reputation, measured through loss of sales growth and negative market reactions for industry peers (contagion). The reputational channel is particularly important because it affects stakeholders beyond shareholders: customers, suppliers, and employees all update their assessments of the firm following a cyber incident, with consequences for revenue, supply chain relationships, and talent acquisition and retention.

The cyber insurance market provides a market-based lens on the pricing of cybersecurity risk. As of 2024, the global cyber insurance market reached approximately USD 15.3 billion in direct written premiums, with North America accounting for USD 10.6 billion (69 percent) and Europe USD 3.3 billion (21 percent) (Munich Re, 2025). The market is projected to reach approximately USD 16.3 billion by the end of 2025, growing at a compound annual rate of approximately 18 percent since 2020.

Notably, U.S. cyber insurance direct written premiums experienced their first-ever annual decline in 2024, falling 7.1 percent to approximately USD 9.1 billion from a peak of USD 9.8 billion in 2023 (NAIC, 2025). Average cyber insurance rates declined approximately 5 percent in the fourth quarter of 2024 alone, even as claim frequency rose nearly 40 percent. This apparent paradox (rising claims alongside softening rates) reflects both increased market capacity from new entrants and improved underwriting discipline tied to better cybersecurity data, partly attributable to enhanced regulatory disclosure.

Ransomware remains the dominant driver of cyber insurance losses. In 2024, the average ransom demand was approximately USD 600,000, and the top three industries by ransomware loss volume were manufacturing, healthcare, and retail (Munich Re, 2025). The potential for systemic cyber risk remains the industry's central concern: Munich Re models suggest accumulation potential of USD 20 to 46 billion in a single aggregation scenario, far exceeding the current capital base of the cyber insurance market. This systemic risk, coupled with the increasing frequency and severity of cyberattacks, raises questions about the long-term insurability of cyber risk without government backstop mechanisms.

## **6.1 Stock Price Reactions to Breaches and Disclosures**

Cybersecurity breaches produce negative and statistically significant stock price reactions. Kamiya et al. (2021, JFE) document that successful cyberattacks lead to negative stock price reactions and significant loss of sales growth for target firms, with average cumulative abnormal returns (CARs) in the range of negative 1 to 3 percent over short event windows. The effect extends beyond the target firm: there is evidence of intra-industry contagion, with non-breached firms in the same industry experiencing negative abnormal returns around major breach announcements.

A 2025 study in the Journal of Banking Regulation examining 53 global cyberattacks finds negative and statistically significant stock price reactions for breached firms around disclosure dates, with stronger reactions for small firms, high-leverage firms, high-growth-opportunity firms, and incidents involving financial information loss. This heterogeneity is important: it suggests that cybersecurity risk interacts with other firm-level risk factors to determine market impact, and that the nature of the compromised information matters alongside the fact of the breach itself.

On the disclosure side, the relationship between disclosure and stock price crash risk is nuanced. A 2024 study in the *International Review of Economics and Finance* finds that data breach disclosures (mandated by state-level Data Breach Notification laws) are associated with increased stock price crash risk, consistent with the argument that disclosure of bad news can itself trigger panic selling. However, research in the *Journal of Corporate Accounting and Finance* (Vol. 36, Issue 3) finds that higher frequency of cybersecurity disclosures (presumably reflecting ongoing risk management communication rather than incident-driven disclosure) is associated with reduced stock price crash risk. The distinction between incident-triggered disclosure and routine risk management disclosure appears critical to understanding disclosure effects.

## **6.2 Cost of Capital**

A growing body of evidence links cybersecurity risk to firms' cost of capital. Sheneman (forthcoming, TAR) provides the most direct evidence on the debt market channel: she documents a positive association between cybersecurity risk and the cost of bank debt, with loans initiated after a breach carrying spreads approximately 30 basis points higher than loans to non-breached firms. The effect is more pronounced for firms with lower pre-breach credit ratings, suggesting that cybersecurity risk compounds existing credit risk rather than operating as an independent factor.

Huang and Wang (2021) show that the passage of state-level Data Breach Notification laws increased breach disclosure rates, which in turn exposed lenders to greater cash flow risk from breach-related costs. On the equity side, Chen et al. (2023, *Journal of Business Ethics*) find that detailed cybersecurity risk factor disclosures reduce information asymmetry and are associated with a lower cost of equity. Wang et al. (2023, *Journal of Accounting and Public Policy*) document a positive association between cybersecurity risk and the cost of equity capital, but find that this association is moderated by the quality of board oversight: firms with strong board-level cybersecurity governance exhibit a weaker relationship between cyber risk and cost of equity.

Havakhor et al. (2020) examine the relationship between cybersecurity investment disclosure and firms' financing costs. They find that digital cybersecurity investments show a stronger negative association with cost of equity compared to cost of debt, consistent with the argument that equity holders, who hold residual claims on firm value, are more exposed to the downside risk of cybersecurity failures and therefore more sensitive to investments that mitigate that risk.

## **6.3 Litigation, Enforcement, and Reputation**

The SEC's October 2024 enforcement actions against four companies for materially misleading disclosures related to the SolarWinds Orion intrusion signal a new era of regulatory scrutiny over cybersecurity disclosure (SEC, 2024). Total civil penalties in these four actions amounted to approximately USD 7 million. Beyond SEC enforcement, shareholder derivative lawsuits and

securities class actions following cybersecurity incidents are increasing. The combination of mandatory incident reporting (creating a publicly available record of incidents) and the SEC's demonstrated willingness to pursue disclosure violations creates a new litigation environment for public companies.

Kamiya et al. (2021) document that beyond direct financial costs, cybersecurity breaches damage firm reputation, measured through loss of sales growth and negative market reactions for industry peers (contagion). The reputational channel is particularly important because it affects stakeholders beyond shareholders: customers, suppliers, and employees all update their assessments of the firm following a cyber incident, with consequences for revenue, supply chain relationships, and talent acquisition and retention.

## **6.4 Cyber Insurance**

The cyber insurance market provides a market-based lens on the pricing of cybersecurity risk. As of 2024, the global cyber insurance market reached approximately USD 15.3 billion in direct written premiums, with North America accounting for USD 10.6 billion (69 percent) and Europe USD 3.3 billion (21 percent) (Munich Re, 2025). The market is projected to reach approximately USD 16.3 billion by the end of 2025, growing at a compound annual rate of approximately 18 percent since 2020.

Notably, U.S. cyber insurance direct written premiums experienced their first-ever annual decline in 2024, falling 7.1 percent to approximately USD 9.1 billion from a peak of USD 9.8 billion in 2023 (NAIC, 2025). Average cyber insurance rates declined approximately 5 percent in the fourth quarter of 2024 alone, even as claim frequency rose nearly 40 percent. This apparent paradox (rising claims alongside softening rates) reflects both increased market capacity from new entrants and improved underwriting discipline tied to better cybersecurity data, partly attributable to enhanced regulatory disclosure.

Ransomware remains the dominant driver of cyber insurance losses. In 2024, the average ransom demand was approximately USD 600,000, and the top three industries by ransomware loss volume were manufacturing, healthcare, and retail (Munich Re, 2025). The potential for systemic cyber risk remains the industry's central concern: Munich Re models suggest accumulation potential of USD 20 to 46 billion in a single aggregation scenario, far exceeding the current capital base of the cyber insurance market. This systemic risk, coupled with the increasing frequency and severity of cyberattacks, raises questions about the long-term insurability of cyber risk without government backstop mechanisms.

## **7. Global Systemic Issues**

The global cybersecurity threat environment has deteriorated substantially over the past decade. IBM's Cost of a Data Breach Report (2025), covering 604 organisations across 26 countries and 17 industries, reports a global average breach cost of USD 4.44 million, down slightly from the

2024 record of USD 4.88 million in what the report describes as the first year-over-year decline in five years. However, this aggregate decline masks substantial regional variation: the U.S. average breach cost rose 9 percent year-over-year to a record USD 10.22 million in 2025, and healthcare remained the most expensive sector for the fourteenth consecutive year.

The 2025 Verizon Data Breach Investigations Report, analysing 22,052 incidents and 12,195 confirmed breaches across 139 countries, identifies several concerning trends. The human element remains the most common vector (62 percent of breaches), credential abuse continues to dominate (22 percent of breaches), and vulnerability exploitation as an initial access step grew 34 percent year-over-year. Most strikingly, third-party involvement in breaches doubled to 30 percent from 15 percent in the prior year, underscoring the growing importance of supply-chain risk in the cybersecurity landscape.

Ransomware has evolved from a nuisance into a systemic economic threat. The 2025 Verizon DBIR reports that ransomware was present in 44 percent of all analysed breaches, a 37 percent increase from 32 percent in the prior year. The threat is disproportionately concentrated among smaller businesses: 88 percent of small and medium business (SMB) breaches involved ransomware, compared to 39 percent for large organisations. Yet larger firms face substantially higher financial demands: the average ransom payment across all organisation sizes in 2025 was approximately USD 1.82 million, with enterprise payments averaging USD 2.4 million.

Two behavioural trends are notable. First, victim organisations are increasingly refusing to pay ransoms: the refusal rate rose from approximately 50 percent in 2022 to 64 percent in 2024. Second, organisations that involved law enforcement in their response saved an average of USD 990,000 per breach (an 18 percent reduction in total breach cost), according to IBM (2025). These trends suggest a shift in the economic calculus of ransomware response, driven partly by the recognition that paying ransoms does not guarantee data recovery or prevent subsequent extortion (IBM reports that 47 percent of organisations that paid a ransom had their data leaked regardless).

The global scale of ransomware-related economic damage is difficult to quantify precisely, but available estimates are alarming. Global ransomware damages are projected to exceed USD 265 billion annually by 2031 (Cybersecurity Ventures). The European Union Agency for Cybersecurity (ENISA) estimates that economic damages from ransomware in the EU alone reached EUR 178.6 billion in 2024, up from EUR 30.4 billion in 2023. This nearly six-fold increase in a single year reflects both the growing frequency of attacks and the increasingly severe consequences for critical infrastructure targets.

Cybersecurity threats to critical infrastructure sectors (energy, water, transportation, healthcare, financial services, and communications) represent a distinct category of systemic risk. The Colonial Pipeline ransomware attack (2021), the SolarWinds supply-chain compromise (2020), and the Change Healthcare breach (2024) each demonstrated how a single cybersecurity incident can produce cascading effects across interconnected systems. The U.S. Cybersecurity and Infrastructure Security Agency (CISA) has identified 16 critical infrastructure sectors whose

disruption would have a debilitating effect on national security, economic security, or public health and safety.

The financial sector occupies a unique position in this landscape. As the operator of payment systems, settlement infrastructure, and capital markets, the financial sector is both a high-value target for cyberattacks and a potential vector for systemic contagion. DORA's application to 21 categories of financial entities reflects the European legislator's assessment that the financial sector's ICT resilience is a matter of systemic importance requiring a regulatory framework more stringent than general cybersecurity regulation. The U.S. approach, by contrast, relies on sector-specific regulation (such as the Federal Financial Institutions Examination Council (FFIEC) guidelines and the New York Department of Financial Services cybersecurity regulation) layered on top of the SEC's disclosure requirements.

A fundamental challenge in the governance of cybersecurity risk is the mismatch between the global nature of cyber threats and the jurisdictional nature of regulatory authority. Cybercriminals operate across borders with near impunity, exploiting gaps in extradition treaties, differences in criminal law, and the practical difficulties of attribution. The disclosure regimes that have emerged since 2023 create a particular form of regulatory friction: a single incident may trigger materially different disclosure obligations in multiple jurisdictions, with different timelines, content requirements, materiality standards, and audiences.

The OECD's March 2026 report on international coherence of cybersecurity regulations identifies regulatory fragmentation as a material cost for multinational business. The report suggests several mechanisms for improving regulatory coherence, including mutual recognition of incident reporting, harmonised taxonomies, and joint supervisory frameworks for critical ICT providers. However, the political headwinds against international regulatory harmonisation are substantial, and meaningful progress toward coherent global cybersecurity disclosure standards appears unlikely in the near term.

The intersection of artificial intelligence and cybersecurity represents both a threat amplifier and a defensive opportunity. IBM (2025) reports that one in six breaches involved AI in some form (phishing or deepfake techniques), and that organisations with high "shadow AI" (unsanctioned employee use of AI tools) added an average of USD 670,000 to breach costs. However, organisations that deployed AI and automation extensively in their security operations realised average cost savings of USD 2.2 million per breach and reduced the breach lifecycle by 108 days. These findings suggest that the net effect of AI on the cybersecurity landscape is not predetermined but depends on adoption patterns and governance choices at the organisational and regulatory levels.

## **7.1 Rising Breach Frequency and Cost**

The global cybersecurity threat environment has deteriorated substantially over the past decade. IBM's Cost of a Data Breach Report (2025), covering 604 organisations across 26 countries and

17 industries, reports a global average breach cost of USD 4.44 million, down slightly from the 2024 record of USD 4.88 million in what the report describes as the first year-over-year decline in five years. However, this aggregate decline masks substantial regional variation: the U.S. average breach cost rose 9 percent year-over-year to a record USD 10.22 million in 2025, and healthcare remained the most expensive sector for the fourteenth consecutive year.

The 2025 Verizon Data Breach Investigations Report, analysing 22,052 incidents and 12,195 confirmed breaches across 139 countries, identifies several concerning trends. The human element remains the most common vector (62 percent of breaches), credential abuse continues to dominate (22 percent of breaches), and vulnerability exploitation as an initial access step grew 34 percent year-over-year. Most strikingly, third-party involvement in breaches doubled to 30 percent from 15 percent in the prior year, underscoring the growing importance of supply-chain risk in the cybersecurity landscape.

## **7.2 Ransomware as a Systemic Threat**

Ransomware has evolved from a nuisance into a systemic economic threat. The 2025 Verizon DBIR reports that ransomware was present in 44 percent of all analysed breaches, a 37 percent increase from 32 percent in the prior year. The threat is disproportionately concentrated among smaller businesses: 88 percent of small and medium business (SMB) breaches involved ransomware, compared to 39 percent for large organisations. Yet larger firms face substantially higher financial demands: the average ransom payment across all organisation sizes in 2025 was approximately USD 1.82 million, with enterprise payments averaging USD 2.4 million.

Two behavioural trends are notable. First, victim organisations are increasingly refusing to pay ransoms: the refusal rate rose from approximately 50 percent in 2022 to 64 percent in 2024. Second, organisations that involved law enforcement in their response saved an average of USD 990,000 per breach (an 18 percent reduction in total breach cost), according to IBM (2025). These trends suggest a shift in the economic calculus of ransomware response, driven partly by the recognition that paying ransoms does not guarantee data recovery or prevent subsequent extortion (IBM reports that 47 percent of organisations that paid a ransom had their data leaked regardless).

The global scale of ransomware-related economic damage is difficult to quantify precisely, but available estimates are alarming. Global ransomware damages are projected to exceed USD 265 billion annually by 2031 (Cybersecurity Ventures). The European Union Agency for Cybersecurity (ENISA) estimates that economic damages from ransomware in the EU alone reached EUR 178.6 billion in 2024, up from EUR 30.4 billion in 2023. This nearly six-fold increase in a single year reflects both the growing frequency of attacks and the increasingly severe consequences for critical infrastructure targets.

## **7.3 Critical Infrastructure Exposure**

Cybersecurity threats to critical infrastructure sectors (energy, water, transportation, healthcare, financial services, and communications) represent a distinct category of systemic risk. The Colonial Pipeline ransomware attack (2021), the SolarWinds supply-chain compromise (2020), and the Change Healthcare breach (2024) each demonstrated how a single cybersecurity incident can produce cascading effects across interconnected systems. The U.S. Cybersecurity and Infrastructure Security Agency (CISA) has identified 16 critical infrastructure sectors whose disruption would have a debilitating effect on national security, economic security, or public health and safety.

The financial sector occupies a unique position in this landscape. As the operator of payment systems, settlement infrastructure, and capital markets, the financial sector is both a high-value target for cyberattacks and a potential vector for systemic contagion. DORA's application to 21 categories of financial entities reflects the European legislator's assessment that the financial sector's ICT resilience is a matter of systemic importance requiring a regulatory framework more stringent than general cybersecurity regulation. The U.S. approach, by contrast, relies on sector-specific regulation (such as the Federal Financial Institutions Examination Council (FFIEC) guidelines and the New York Department of Financial Services cybersecurity regulation) layered on top of the SEC's disclosure requirements.

## **7.4 Cross-Border Enforcement Gaps and Disclosure Inconsistency**

A fundamental challenge in the governance of cybersecurity risk is the mismatch between the global nature of cyber threats and the jurisdictional nature of regulatory authority. Cybercriminals operate across borders with near impunity, exploiting gaps in extradition treaties, differences in criminal law, and the practical difficulties of attribution. The disclosure regimes that have emerged since 2023 create a particular form of regulatory friction: a single incident may trigger materially different disclosure obligations in multiple jurisdictions, with different timelines, content requirements, materiality standards, and audiences.

The OECD's March 2026 report on international coherence of cybersecurity regulations identifies regulatory fragmentation as a material cost for multinational business. The report suggests several mechanisms for improving regulatory coherence, including mutual recognition of incident reporting, harmonised taxonomies, and joint supervisory frameworks for critical ICT providers. However, the political headwinds against international regulatory harmonisation are substantial, and meaningful progress toward coherent global cybersecurity disclosure standards appears unlikely in the near term.

## **7.5 The Role of AI in Cybersecurity**

The intersection of artificial intelligence and cybersecurity represents both a threat amplifier and a defensive opportunity. IBM (2025) reports that one in six breaches involved AI in some form (phishing or deepfake techniques), and that organisations with high "shadow AI" (unsanctioned employee use of AI tools) added an average of USD 670,000 to breach costs. However,



organisations that deployed AI and automation extensively in their security operations realised average cost savings of USD 2.2 million per breach and reduced the breach lifecycle by 108 days. These findings suggest that the net effect of AI on the cybersecurity landscape is not predetermined but depends on adoption patterns and governance choices at the organisational and regulatory levels.

## 8. Research Opportunities

The convergence of new mandatory disclosure regimes, rich datasets, and unresolved theoretical questions creates fertile ground for accounting, finance, and governance research. Below, research opportunities are organised by thematic area, with suggestions for data sources, identification strategies, and theoretical framing. Figure 12 provides a visual mapping of these opportunities across methods, data, and impact areas.

The SEC's principles-based materiality framework for cybersecurity incidents creates natural variation that researchers can exploit. Key questions include: What factors explain the decision to file under Item 1.05 rather than Items 8.01 or 7.01? Does the market react differently to incidents reported under different items? How do investors use the materiality characterisation provided by management? The availability of granular Form 8-K filing data from SEC EDGAR, combined with the fact that approximately 85 percent of incident filings do not include quantitative impact estimates, suggests opportunities for research on the information content of qualitative versus quantitative disclosure.

The SEC's mandate creates a setting in which all firms must disclose cybersecurity risk management and governance under Item 106, but the content and specificity of these disclosures vary widely. This variation allows researchers to examine whether the quality of cybersecurity governance disclosure (not merely its presence) affects market outcomes. Natural questions include: Does more specific board oversight disclosure reduce the negative market reaction to a subsequent breach? Are firms with detailed third-party risk management disclosures less affected by supply-chain cyber events? Does disclosure specificity predict future breach incidence?

Item 106(c) requires firms to disclose both the board's oversight processes and management's cybersecurity expertise. This creates a new, standardised dataset for research on the governance of cybersecurity risk. Key research questions include: Is board cybersecurity expertise, as disclosed under Item 106, associated with lower breach incidence or faster breach detection? Does the market price board cybersecurity expertise, and if so, through what channel (lower expected breach probability, lower expected breach cost, or both)? How does the effectiveness of board cybersecurity oversight interact with the board's broader governance characteristics?

The differential timing and design of cybersecurity disclosure mandates across jurisdictions creates opportunities for difference-in-differences and comparative institutional analysis. The SEC rules (effective late 2023), NIS2 (transposed by member states through late 2024), and DORA (applicable from January 2025) create a staggered adoption setting. Researchers can

examine whether mandatory disclosure affects breach incidence, breach detection speed, cybersecurity investment, or capital market outcomes, using jurisdictions without equivalent mandates as control groups.

The Verizon 2025 DBIR reports that third-party involvement in breaches doubled from 15 to 30 percent between 2024 and 2025. Item 106(b) requires firms to disclose their processes for identifying and managing third-party cybersecurity risk. This setting allows researchers to examine the economic effects of supply-chain cybersecurity risk management: Does third-party risk disclosure predict supply-chain resilience to cyber events? Is there evidence of spillover effects from a firm's cybersecurity practices to its suppliers or customers? How do investors price third-party cyber risk?

The cyber insurance market provides a market-based measure of cybersecurity risk that can complement disclosure-based measures. Research opportunities include examining whether firms that carry cyber insurance disclose differently under the SEC mandate, whether the availability and price of cyber insurance affect firms' cybersecurity investment decisions, and whether the disclosure mandate has affected the pricing or availability of cyber insurance.

## **8.1 Materiality Determination**

The SEC's principles-based materiality framework for cybersecurity incidents creates natural variation that researchers can exploit. Key questions include: What factors explain the decision to file under Item 1.05 rather than Items 8.01 or 7.01? Does the market react differently to incidents reported under different items? How do investors use the materiality characterisation provided by management? The availability of granular Form 8-K filing data from SEC EDGAR, combined with the fact that approximately 85 percent of incident filings do not include quantitative impact estimates, suggests opportunities for research on the information content of qualitative versus quantitative disclosure.

## **8.2 Disclosure Credibility and Market Effects**

The SEC's mandate creates a setting in which all firms must disclose cybersecurity risk management and governance under Item 106, but the content and specificity of these disclosures vary widely. This variation allows researchers to examine whether the quality of cybersecurity governance disclosure (not merely its presence) affects market outcomes. Natural questions include: Does more specific board oversight disclosure reduce the negative market reaction to a subsequent breach? Are firms with detailed third-party risk management disclosures less affected by supply-chain cyber events? Does disclosure specificity predict future breach incidence?

## **8.3 Board Governance and Cybersecurity Expertise**

Item 106(c) requires firms to disclose both the board's oversight processes and management's cybersecurity expertise. This creates a new, standardised dataset for research on the governance

of cybersecurity risk. Key research questions include: Is board cybersecurity expertise, as disclosed under Item 106, associated with lower breach incidence or faster breach detection? Does the market price board cybersecurity expertise, and if so, through what channel (lower expected breach probability, lower expected breach cost, or both)? How does the effectiveness of board cybersecurity oversight interact with the board's broader governance characteristics?

## **8.4 International Comparative Research**

The differential timing and design of cybersecurity disclosure mandates across jurisdictions creates opportunities for difference-in-differences and comparative institutional analysis. The SEC rules (effective late 2023), NIS2 (transposed by member states through late 2024), and DORA (applicable from January 2025) create a staggered adoption setting. Researchers can examine whether mandatory disclosure affects breach incidence, breach detection speed, cybersecurity investment, or capital market outcomes, using jurisdictions without equivalent mandates as control groups.

## **8.5 Third-Party and Supply-Chain Risk**

The Verizon 2025 DBIR reports that third-party involvement in breaches doubled from 15 to 30 percent between 2024 and 2025. Item 106(b) requires firms to disclose their processes for identifying and managing third-party cybersecurity risk. This setting allows researchers to examine the economic effects of supply-chain cybersecurity risk management: Does third-party risk disclosure predict supply-chain resilience to cyber events? Is there evidence of spillover effects from a firm's cybersecurity practices to its suppliers or customers? How do investors price third-party cyber risk?

## **8.6 Cyber Insurance and Risk Transfer**

The cyber insurance market provides a market-based measure of cybersecurity risk that can complement disclosure-based measures. Research opportunities include examining whether firms that carry cyber insurance disclose differently under the SEC mandate, whether the availability and price of cyber insurance affect firms' cybersecurity investment decisions, and whether the disclosure mandate has affected the pricing or availability of cyber insurance.

## **9. Conclusion**

The adoption of mandatory cybersecurity disclosure rules by the SEC in July 2023 represents a watershed moment in the governance of corporate cybersecurity risk. In the approximately two and a half years since the rules took effect, a rich picture has emerged: 55 incidents reported under Item 1.05 in the first year, substantial variation in materiality judgments and disclosure specificity, early enforcement actions signalling the SEC's intent to pursue misleading

disclosures, and the parallel development of disclosure frameworks in the European Union, Asia-Pacific, and beyond.

Several themes emerge from this review. First, materiality determination is the central challenge of the new disclosure regime: the prevalence of "undetermined" characterisations in initial filings and the dramatic shift from Item 1.05 to Item 8.01 following the SEC's May 2024 guidance both reflect the practical difficulty of applying a forward-looking materiality standard to cybersecurity incidents. Second, the disclosure mandate generates new information: textual analysis of Item 1C disclosures shows that the governance and process focus of the new requirements produces content that is fundamentally distinct from what firms previously disclosed voluntarily. Third, the global regulatory landscape is fragmenting: the SEC, NIS2, and DORA frameworks reflect different regulatory philosophies and impose different reporting requirements on multinational firms, creating a complex compliance environment and rich opportunities for comparative research.

For accounting and finance scholars, the post-mandate period provides several structural advantages for empirical research. The mandate creates a panel of standardised cybersecurity disclosures, enabling within-firm analysis of disclosure changes. The staggered adoption across jurisdictions supports difference-in-differences research designs. The well-defined event dates for cybersecurity incident disclosures support short-window event studies. And the availability of machine-readable EDGAR filings, combined with advances in textual analysis and natural language processing, enables large-scale analysis of disclosure content, tone, and specificity.

The cybersecurity disclosure literature is at an early stage relative to the maturity of the underlying phenomenon. As more data accumulate through successive years of mandatory filing, and as the regulatory framework stabilises or evolves in response to experience, the research opportunities identified in this brief will become increasingly tractable. The challenge for accounting and finance scholars is to develop theoretically grounded, empirically rigorous research that speaks both to the academic literature and to the needs of investors, regulators, and firms navigating an increasingly complex cybersecurity disclosure landscape.

## References

- [1] Alodat, A. Y., Salleh, Z., Hashim, H. A., and Sulong, F. (2024). Corporate governance and cybersecurity risk disclosure: Evidence from an emerging market. *Corporate Governance: The International Journal of Business in Society*, 24(2), 405-432.
- [2] Amir, E., Levi, S., and Livne, T. (2018). Do firms underreport information on cyber-attacks? Evidence from capital markets. *Review of Accounting Studies*, 23(3), 1177-1206. <https://doi.org/10.1007/s11142-018-9452-4> (<https://doi.org/10.1007/s11142-018-9452-4>)
- [3] Chen, J., Henry, E., and Jiang, X. (2023). Is cybersecurity risk factor disclosure informative? Evidence from disclosures following a data breach. *Journal of Business Ethics*, 187, 199-224. <https://doi.org/10.1007/s10551-022-05107-z> (<https://doi.org/10.1007/s10551-022-05107-z>)
- [4] Beyer, A., Cohen, D. A., Lys, T. Z., and Walther, B. R. (2010). The financial reporting environment: Review of the recent literature. *Journal of Accounting and Economics*, 50(2-3), 296-343.
- [5] Eaton, T. V., Grenier, J. H., and Layman, S. M. (2019). The impact of data breach announcements on shareholder wealth in the banking industry. *Journal of the Association for Information Systems*, 20(10), 1471-1507. <https://doi.org/10.17705/1jais.00568> (<https://doi.org/10.17705/1jais.00568>)
- [6] Elnahass, M., Ahmed, Y., and Trinh, V. Q. (2024). Empowering women to lead cybersecurity: The effect of female executives on disclosure sentiment. *International Journal of Finance and Economics*, forthcoming. <https://doi.org/10.1002/ijfe.3067> (<https://doi.org/10.1002/ijfe.3067>)
- [7] Florackis, C., Louca, C., Michaely, R., and Weber, M. (2023). Cybersecurity risk. *The Review of Financial Studies*, 36(1), 351-407. <https://doi.org/10.1093/rfs/hhac049> (<https://doi.org/10.1093/rfs/hhac049>)
- [8] Gao, L., Calderon, T. G., and Tang, F. (2020). Public companies' cybersecurity risk disclosures. *International Journal of Accounting Information Systems*, 38, 100468. <https://doi.org/10.1016/j.accinf.2020.100468> (<https://doi.org/10.1016/j.accinf.2020.100468>)
- [9] Gordon, L. A., Loeb, M. P., and Sohail, T. (2020). A framework for voluntary cybersecurity disclosure by public companies. *Journal of Information Systems*, 34(3), 87-103. <https://doi.org/10.2308/isyss-52561> (<https://doi.org/10.2308/isyss-52561>)
- [10] Haislip, J. Z., Lim, J.-H., and Pinsker, R. (2026). Mandatory cybersecurity disclosure: Early evidence from 10-K reports. *International Journal of Accounting Information Systems*, 56, 100748. <https://doi.org/10.1016/j.accinf.2025.100748> (<https://doi.org/10.1016/j.accinf.2025.100748>)
- [11] Hartmann, B., and Carmenate, J. (2021). Academic research on the role of corporate governance and IT expertise in addressing cybersecurity breaches. *Current Issues in Auditing*, 15(2), A9-A23. <https://doi.org/10.2308/CIIA-2020-020> (<https://doi.org/10.2308/CIIA-2020-020>)
- [12] Havakhor, T., Rahman, M. S., and Zhang, T. (2020). Disclosure of cybersecurity investments and the cost of capital. Working paper, presented at the Workshop on the Economics of Information Security (WEIS), Brussels. <https://ssrn.com/abstract=3553470> (<https://ssrn.com/abstract=3553470>)
- [13] Healy, P. M., and Palepu, K. G. (2001). Information asymmetry, corporate disclosure, and the capital markets: A review of the empirical disclosure literature. *Journal of Accounting and Economics*, 31(1-3), 405-440.
- [14] Higgs, J. L., Pinsker, R. E., Smith, T. J., and Young, G. R. (2016). The relationship between board-level technology committees and reported security breaches. *Journal of Information Systems*, 30(3), 79-98.
- [15] Huang, H. H., and Wang, C. (2021). Do banks price firms' data breaches? *The Accounting Review*, 96(3), 261-286. <https://doi.org/10.2308/TAR-2018-0643> (<https://doi.org/10.2308/TAR-2018-0643>)
- [16] Juma'h, A. H., and Alnsour, Y. (2020). The effect of data breaches on company performance. *International Journal of Accounting and Information Management*, 28(2), 275-301. <https://doi.org/10.1108/IJAIM-01-2019-0006> (<https://doi.org/10.1108/IJAIM-01-2019-0006>)

- [17] Kamiya, S., Kang, J.-K., Kim, J., Milidonis, A., and Stulz, R. M. (2021). Risk management, firm reputation, and the impact of successful cyberattacks on target firms. *Journal of Financial Economics*, 139(3), 719-749. <https://doi.org/10.1016/j.jfineco.2019.05.019> (<https://doi.org/10.1016/j.jfineco.2019.05.019>)
- [18] Li, H., No, W. G., and Wang, T. (2022). Cybersecurity risk and audit pricing. *Auditing: A Journal of Practice and Theory*, 41(4), 115-143. <https://doi.org/10.2308/AJPT-2020-090> (<https://doi.org/10.2308/AJPT-2020-090>)
- [19] Lin, C., and She, G. (2024). Insider trading before cybersecurity breach announcements. *Journal of Corporate Finance*, 84, 102534.
- [20] Mazumder, M. M. M., and Hossain, D. M. (2023). Corporate governance and voluntary cybersecurity disclosure: Evidence from Australia. *Pacific Accounting Review*, 35(3), 452-479.
- [21] Radu, C., and Smaili, N. (2022). Board gender diversity and corporate response to cyber risk: Evidence from cybersecurity related disclosure. *Journal of Business Ethics*, 177(1), 53-70.
- [22] Sheneman, A. G. (forthcoming). Cybersecurity risk and bank loan contracting. *The Accounting Review*.
- [23] Smaili, N., Radu, C., and Khalili, A. (2023). Board characteristics and cybersecurity disclosure: Evidence from the UK. *Journal of Applied Accounting Research*, 24(5), 838-861.
- [24] Trinh, V. Q., Cao, N. D., Nguyen, T. T., and Nguyen, T. P. (2025). CEO characteristics and cybersecurity disclosure: International evidence. *International Review of Financial Analysis*, 91, 103102.
- [25] Wang, T., Kannan, K., and Ulmer, J. R. (2023). Cybersecurity risk and the cost of equity capital. *Journal of Accounting and Public Policy*, 42(4), 107126. <https://doi.org/10.1016/j.jaccpubpol.2023.107126> (<https://doi.org/10.1016/j.jaccpubpol.2023.107126>)
- [26] Cybersecurity Ventures (2023). Global Ransomware Damage Costs Predicted to Exceed \$265 Billion by 2031. <https://cybersecurityventures.com/ransomware-report-2023/> (<https://cybersecurityventures.com/ransomware-report-2023/>)
- [27] ENISA (2024). ENISA Threat Landscape 2024. European Union Agency for Cybersecurity. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024> (<https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>)
- [28] European Commission (2022). Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive). *Official Journal of the European Union*, L 333, 27 December 2022.
- [29] European Commission (2022). Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA). *Official Journal of the European Union*, L 333, 27 December 2022.
- [30] European Union (2016). Regulation (EU) 2016/679 (General Data Protection Regulation). *Official Journal of the European Union*, L 119, 4 May 2016.
- [31] Gibson Dunn (2025). Cybersecurity disclosure overview: A survey of Form 10-K cybersecurity disclosures by S&P 100 companies. *Harvard Law School Forum on Corporate Governance*, 9 January 2025. <https://corpgov.law.harvard.edu/2025/01/09/cybersecurity-disclosure-overview-a-survey-of-form-10-k-cybersecurity-disclosures-by-sp-100-companies/> (<https://corpgov.law.harvard.edu/2025/01/09/cybersecurity-disclosure-overview-a-survey-of-form-10-k-cybersecurity-disclosures-by-sp-100-companies/>)
- [32] IBM Security (2025). Cost of a Data Breach Report 2025. IBM Corporation and Ponemon Institute. <https://www.ibm.com/reports/data-breach> (<https://www.ibm.com/reports/data-breach>)
- [33] IBM Security (2024). Cost of a Data Breach Report 2024. IBM Corporation and Ponemon Institute. <https://www.ibm.com/reports/data-breach> (<https://www.ibm.com/reports/data-breach>)
- [34] Munich Re (2025). Cyber Insurance: Risks and Trends 2025. Munich Reinsurance Company. <https://www.munichre.com/en/insights/cyber/cyber-insurance-risks-and-trends-2025.html> (<https://www.munichre.com/en/insights/cyber/cyber-insurance-risks-and-trends-2025.html>)
- [35] NAIC (2025). Report on the Cybersecurity Insurance Market. National Association of Insurance Commissioners. <https://content.naic.org/sites/default/files/inline->

files/2025\_Cybersecurity\_Insurance%20Report.pdf ([https://content.naic.org/sites/default/files/inline-files/2025\\_Cybersecurity\\_Insurance%20Report.pdf](https://content.naic.org/sites/default/files/inline-files/2025_Cybersecurity_Insurance%20Report.pdf))

- [36] OECD (2026). Towards International Coherence of Cybersecurity Regulations. OECD Publishing. <https://doi.org/10.1787/bd1f199a-en> (<https://doi.org/10.1787/bd1f199a-en>)
- [37] SEC (2023). Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure. Final Rule, Release No. 33-11216, 26 July 2023. <https://www.sec.gov/files/rules/final/2023/33-11216.pdf> (<https://www.sec.gov/files/rules/final/2023/33-11216.pdf>)
- [38] SEC (2024). SEC Charges Four Companies for Misleading Cybersecurity Disclosures Related to SolarWinds. Press Release 2024-174, 22 October 2024. <https://www.sec.gov/newsroom/press-releases/2024-174> (<https://www.sec.gov/newsroom/press-releases/2024-174>)
- [39] SEC (2024). Statement by Erik Gerding, Director, Division of Corporation Finance, on Cybersecurity Incident Disclosures. 21 May 2024. <https://www.sec.gov/newsroom/speeches-statements/gerding-cybersecurity-incidents-05212024> (<https://www.sec.gov/newsroom/speeches-statements/gerding-cybersecurity-incidents-05212024>)
- [40] SEC (2024). Compliance and Disclosure Interpretations: Cybersecurity. 24 June 2024. <https://www.sec.gov/divisions/corpfin/guidance/candis-cfcc-cybersecurity.htm> (<https://www.sec.gov/divisions/corpfin/guidance/candis-cfcc-cybersecurity.htm>)
- [41] Verizon (2025). 2025 Data Breach Investigations Report. Verizon Enterprise Solutions. <https://www.verizon.com/business/resources/reports/dbir/> (<https://www.verizon.com/business/resources/reports/dbir/>)
- [42] Verizon (2024). 2024 Data Breach Investigations Report. Verizon Enterprise Solutions. <https://www.verizon.com/business/resources/reports/dbir/> (<https://www.verizon.com/business/resources/reports/dbir/>)
- [43] Wilson Sonsini (2025). Snapshot: the first year of cybersecurity incident filings on Form 8-K since adoption of new rules. Known Trends, 6 February 2025. <https://www.knowntrends.com/2025/02/snapshot-the-first-year-of-cybersecurity-incident-filings-on-form-8-k-since-adoption-of-new-rules/> (<https://www.knowntrends.com/2025/02/snapshot-the-first-year-of-cybersecurity-incident-filings-on-form-8-k-since-adoption-of-new-rules/>)